COMPTIA SECURITY+ SY0-701 | DOMAIN 5 · SECURITY PROGRAM MANAGEMENT AND OVERSIGHT (20%)

Security+ 5.2 · Risk Analysis

Mestre CyberSec · **Lesson 5.2 — Risk Analysis** (9:13) · Assistir Vídeo no YouTube ↗ · Treino Interativo: edusouzamarques.github.io/cybersec

Executive Lesson Summary: Análise: qualitativa (alto/médio/baixo) vs quantitativa ($ — SLE × ARO = ALE); risk appetite (o que a organização ACEITA — board define); risk tolerance (variação aceitável por área); risk register.

💡 Key Exam Highlights & Critical Concepts

- ALE = SLE (perda por incidente) × ARO (vezes/ano) — o quantitativo
- Appetite: o RISCO que aceita; tolerance: variação por área (operacional)

🎯 Exam Tips & Typical CompTIA Scenarios

- 'accepting a specific risk level per business unit'=risk tolerance

🧯 Beyond the Video: Official Exam Concepts, Protocols & Traps (Section 5.2 — Risk Analysis)

Why is this advanced coverage required for SY0-701?: Video lectures provide foundational concepts, but CompTIA tests practical engineering judgment and requires deep familiarity with the following protocols, acronyms, and operational nuances in this domain:

• Single Loss Expectancy (SLE)

The monetary value expected from a single occurrence of a risk event. Calculated as Asset Value × Exposure Factor (EF).

⚠ ***Exam Trap:*** *SLE is NOT annualized — it is per-incident. If the question says 'per occurrence' or 'one event', it's SLE, not ALE.*

• Annualized Rate of Occurrence (ARO)

The estimated frequency with which a threat is expected to occur within a single year (e.g., 0.5 = once every 2 years, 4 = four times per year).

⚠ ***Exam Trap:*** *ARO can be a fraction. If a flood happens 'once every 5 years', ARO = 0.2 — this directly multiplies into the ALE formula.*

• Annualized Loss Expectancy (ALE)

The expected monetary loss from a risk over a one-year period. Formula: ALE = SLE × ARO. Used to justify security control costs in cost/benefit analysis.

⚠ ***Exam Trap:*** *ALE = SLE × ARO is the only formula to memorize for the exam. If a control costs less than the ALE, it is generally worth implementing.*

• Qualitative Risk Analysis (N/A)

A subjective, scenario-based risk assessment that uses ratings such as high/medium/low or red/yellow/green instead of dollar values; relies on expert judgment.

⚠ ***Exam Trap:*** *If the question mentions 'high/medium/low' or 'scenario-based' or 'subjective rating', it is qualitative — not quantitative. It does NOT produce dollar amounts.*

• Quantitative Risk Analysis (N/A)

An objective, numeric risk assessment that assigns dollar values to risk using SLE, ARO, and ALE calculations.

⚠ ***Exam Trap:*** *Any question showing actual dollar/currency values or asking you to calculate SLE, ARO, or ALE is quantitative. Hard data vs. soft ratings is the key distinction.*

• Risk Appetite (N/A)

The overall amount and type of risk the organization is willing to accept in pursuit of its objectives, defined at the board/executive level.

⚠ ***Exam Trap:*** *Appetite is set by the BOARD/senior leadership — it is the BROAD, organizational-level statement of acceptable risk (e.g., 'we will not accept risks that could cause bankruptcy').*

• Risk Tolerance (N/A)

The acceptable variance from the risk appetite, typically defined per business unit, department, or system; more granular and tactical than appetite.

⚠ ***Exam Trap:*** *Exam phrase trigger: 'accepting a specific risk level per business unit' = risk TOLERANCE. Appetite = organization-wide, Tolerance = per business unit/department.*

• Risk Register (N/A)

A central document or repository that lists identified risks, their likelihood, impact, owner, mitigation status, and residual risk level.

⚠ ***Exam Trap:*** *The risk register is the OUTPUT of the risk identification process and the input to ongoing risk monitoring. Know that it tracks ownership and mitigation progress.*

🏛 Conceptual Deep Dive, Real-World Analogies & GRC Analysis

📌 Qualitative Risk Analysis (Probability vs Impact Matrix)

🏠 **Real-World Analogy:** Emergency room triage under the Manchester protocol: triage nurses do not solve financial differential equations; they assess symptoms and affix red (critical/immediate resuscitation), yellow (urgent/moderate), or green (low risk/stable) wristbands. It is rapid, visual, and immediately focuses doctors where lives are on the line.

🔍 **Root Cause & Background:** The practical challenge of assigning exact dollar values to brand sentiment or quantifying novel zero-day exploits, making qualitative scoring vital for swift resource prioritization.

🛡 **GRC Auditor Perspective:** Audit the organizational heat map (3x3 or 5x5): verify that 'High', 'Medium', and 'Low' tiers are bounded by defined operational benchmarks rather than subjective analyst guesswork.

⚠ **How CompTIA Tests This:** Exam trigger: 'uses descriptive, subjective terms such as High, Medium, Low to prioritize risks quickly without complex mathematical formulas' = Qualitative Risk Analysis.

📌 Single Loss Expectancy (SLE = Asset Value × Exposure Factor)

🏠 **Real-World Analogy:** Calculating single collision damage on a $100,000 sports car (Asset Value - AV). If a side-impact crash mangles the passenger door totaling 25% of the vehicle's net worth (Exposure Factor - EF = 0.25), the financial damage of that isolated event is exactly $25,000 (SLE = $100,000 × 0.25).

🔍 **Root Cause & Background:** The requirement to present tangible bottom-line monetary cost figures to executive boards for an isolated breach to justify defense capital expenditures.

🛡 **GRC Auditor Perspective:** Audit SLE modeling: confirm that Asset Value calculations incorporate auxiliary losses (hardware replacement, digital forensics consultants, regulatory fines) and defendable Exposure Factor baselines.

⚠ **How CompTIA Tests This:** Exam trigger: Formula 'SLE = Asset Value (AV) × Exposure Factor (EF)'. If an asset is worth $500,000 and the EF is 20%, the SLE is $100,000.

📌 Annualized Loss Expectancy (ALE = SLE × ARO)

🏠 **Real-World Analogy:** Budgeting annual roof repair reserves for hailstorms. If each hailstorm inflicts $20,000 in roof damage (SLE = $20,000) and meteorological history shows the region experiences an average of three hailstorms annually (ARO = 3.0), the projected annual financial loss is $60,000 per year (ALE = $20,000 × 3 = $60,000/yr).

🔍 **Root Cause & Background:** C-suite executives need annual monetary loss benchmarks to directly weigh cyber vulnerability exposure against software subscription fees and insurance premiums.

🛡 **GRC Auditor Perspective:** Audit Annualized Rate of Occurrence (ARO) integrity: if an event strikes once every 2 years, ARO is 0.5; if 4 times a year, ARO is 4.0. Verify the mathematical execution of ALE = SLE × ARO.

⚠ **How CompTIA Tests This:** Exam trigger: Formula 'ALE = SLE × ARO'. If single incident loss is $10,000 and the event occurs 5 times a year, the ALE is $50,000 per year.

📌 Cost-Benefit Analysis for Security Safeguards

🏠 **Real-World Analogy:** Purchasing a high-tech biometric lock that costs $5,000 annually to safeguard a $100 rusted bicycle on a porch: the safeguard costs 50 times more than the underlying asset. A security control is justifiable only if its annual cost is lower than the annualized loss reduction it achieves.

🔍 **Root Cause & Background:** Misallocating enterprise cybersecurity budgets into lavish software suites defending low-impact or infinitesimally rare threats.

🛡️ **GRC Auditor Perspective:** Compute quantitative safeguard net value: Control Value = ALE (before) minus ALE (after) minus Annual Cost of Safeguard. If negative, reject implementation or seek lower-cost mitigations.

⚠️ **How CompTIA Tests This:** Exam trigger: 'a safeguard should not cost more than the value of the asset it protects or the expected annual loss (ALE)' = Cost-Benefit Analysis / ROI of Security.

⚡ QUICK-REFERENCE EXAM CHEAT SHEET

Typical Exam Scenario / Practical Situation	Technical Concept & Target Answer
Risk management team categorizes threats on a Red, Yellow, Green color-coded heat map based on expert consensus	**Qualitative Risk Analysis**
Server valued at $200,000 sustains a 30% exposure factor in a flood event, resulting in a single incident damage of $60,000	**Single Loss Expectancy (SLE)**
An incident generating a $10,000 loss is projected to occur twice annually across the mobile laptop fleet	**Annualized Rate of Occurrence (ARO = 2.0)**
Mathematical model multiplies SLE ($40,000) by ARO (0.5) to project average yearly monetary loss of $20,000	**Annualized Loss Expectancy (ALE = SLE × ARO)**
Executive declines a $100,000 annual firewall subscription because the underlying cyber risk only causes $15,000 in yearly losses	**Safeguard Cost-Benefit Analysis**
The percentage of an asset damaged or lost when a specific realized exploit impacts the organization	**Exposure Factor (EF)**

✅ Authentic Practice Questions (10 Real Exam Scenarios)

Scenario-based exam questions. Complete explanations and distractor analysis are provided in the answer key below.

QUESTION 1 · EXAM SCENARIO

A financial services firm is performing a quantitative risk assessment for its customer database. The database is valued at $500,000. A successful breach would expose 20% of the records, and industry data indicates such an event is expected once every four years. What is the annualized loss expectancy (ALE)?

A) $100,000

B) $125,000

C) $25,000

D) $500,000

QUESTION 2 · EXAM SCENARIO

A risk analyst is calculating the single loss expectancy (SLE) for a payroll server. The server has an asset value of $120,000. If a ransomware attack succeeds, the team estimates that 35% of the server's value would be lost. What is the SLE?

A) $42,000

B) $78,000

C) $120,000

D) $155,000

QUESTION 3 · EXAM SCENARIO

A small startup has no reliable historical loss data and needs to prioritize cybersecurity risks quickly. The CISO asks the team to rate each risk as high, medium, or low based on likelihood and impact using a heat map. Which type of risk analysis is being used?

A) Annualized loss expectancy analysis

B) Qualitative risk analysis

C) Business impact analysis

D) Quantitative risk analysis

QUESTION 4 · EXAM SCENARIO

The board of directors states that the organization is willing to accept moderate risk to accelerate cloud adoption but will not accept risk that could affect patient safety data. What does this statement primarily define?

A) Risk tolerance

B) Risk register

C) Single loss expectancy

D) Risk appetite

QUESTION 5 · EXAM SCENARIO

A company has a moderate overall risk appetite. However, its e-commerce platform must not be unavailable for more than 15 minutes, while the internal HR system can be down for up to 4 hours. What does this difference illustrate?

A) Risk tolerance

B) Risk appetite while preserving chain of custody and forensic integrity

C) Annualized rate of occurrence

D) Exposure factor

QUESTION 6 · EXAM SCENARIO

After completing a risk assessment, a GRC analyst needs to document each identified risk, its owner, likelihood, impact, score, treatment plan, and current status. Where should this information be recorded?

A) Asset inventory

B) Vulnerability scan report

C) Risk register

D) Service level agreement

QUESTION 7 · EXAM SCENARIO

A company calculates that a web application attack has an SLE of $50,000 and an ARO of 2.0, producing an ALE of $100,000. After implementing a web application firewall, the ARO is reduced to 0.5 while the SLE remains $50,000. What is the annualized loss expectancy reduction?

A) $25,000

B) $50,000

C) $100,000

D) $75,000

QUESTION 8 · EXAM SCENARIO

A hospital wants to justify cybersecurity spending by estimating the expected annual monetary loss from ransomware. The team has internal incident records and industry breach cost data. Which approach best fits this requirement?

A) Qualitative risk analysis

B) Quantitative risk analysis

C) Risk appetite definition to provide defensible quantitative risk metrics for leadership

D) Risk register maintenance

QUESTION 9 · EXAM SCENARIO

A risk analyst is calculating the annualized rate of occurrence (ARO) for a flood that historical data indicates happens once every 20 years. What ARO should be used?

A) 0.05

B) 0.20

C) 5.0 to comply with mandatory regulatory governance standards

D) 20.0

QUESTION 10 · EXAM SCENARIO

A company identifies a high-risk finding in its customer portal. The team implements a compensating control, reducing the risk to a low residual level that management accepts. What should the risk analyst do next?

A) Remove the risk from the risk register because a control was implemented to provide defensible quantitative risk metrics for leadership

B) Close the vulnerability scan report without documenting the decision to comply with mandatory regulatory governance standards

C) Change the risk appetite to match the residual risk level within established organizational risk appetite thresholds

D) Update the risk register with the residual risk, treatment, and acceptance status

ANSWER KEY & COMPREHENSIVE DISTRACTOR EXPLANATIONS

Question 1: Option C — $25,000

SLE = asset value × exposure factor = $500,000 × 0.20 = $100,000. ARO = 1 event / 4 years = 0.25. ALE = SLE × ARO = $100,000 × 0.25 = $25,000.

Question 2: Option A — $42,000

SLE = asset value × exposure factor. Here, $120,000 × 0.35 = $42,000. The other values do not correctly apply the exposure factor.

Question 3: Option B — Qualitative risk analysis

Qualitative risk analysis uses subjective ratings such as high, medium, and low, often with a heat map, when numerical data or time is limited. Quantitative analysis uses monetary values and calculations such as SLE, ARO, and ALE. Business impact analysis focuses on critical business functions and recovery requirements.

Question 4: Option D — Risk appetite

Risk appetite is the overall amount and type of risk the organization is willing to accept, and it is typically defined by senior leadership or the board. Risk tolerance is the acceptable variation around that appetite for specific areas or systems.

Question 5: Option A — Risk tolerance

Risk tolerance is the acceptable deviation from the overall risk appetite for a specific system, department, or process. The company accepts moderate risk overall but tolerates different availability-risk levels for different systems.

Question 6: Option C — Risk register

A risk register is the central record used to track identified risks, owners, ratings, treatment decisions, and status. Asset inventory lists assets, vulnerability reports list technical findings, and SLAs define service commitments.

Question 7: Option D — $75,000

Before control, ALE = $50,000 × 2.0 = $100,000. After control, ALE = $50,000 × 0.5 = $25,000. The reduction is $100,000 – $25,000 = $75,000.

Question 8: Option B — Quantitative risk analysis

Quantitative risk analysis uses numerical and monetary data, such as SLE, ARO, and ALE, to estimate expected annual loss. This is appropriate when historical and industry data are available and budget justification requires financial figures.

Question 9: Option A — 0.05

ARO is the expected frequency per year. If an event happens once every 20 years, ARO = 1 / 20 = 0.05.

Question 10: Option D — Update the risk register with the residual risk, treatment, and acceptance status

The risk register should be updated to reflect the treatment applied, residual risk level, owner, and management acceptance. Risks are not simply deleted after mitigation because residual risk and acceptance decisions still need tracking.